SECURITY

OIDC & SAML Visual Guide

Federated identity —
one login, many apps, no password sprawl.

ANIMATED WALKTHROUGH
Step through pages to play the animation

STEP 1/6

The Federation Triangle

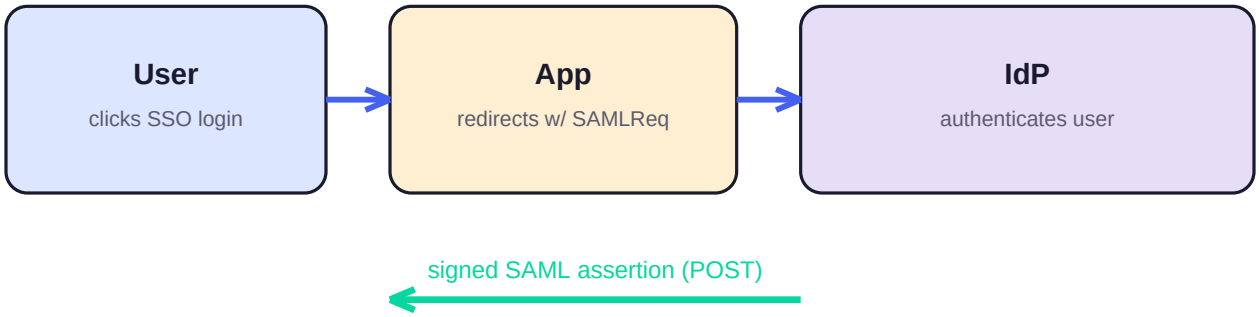
One identity provider vouches for you to every app.

The app never sees your password — it trusts a signed token from the IdP instead.

STEP 2/6

SAML: Assertion Flow

The classic enterprise SSO handshake (XML-based).

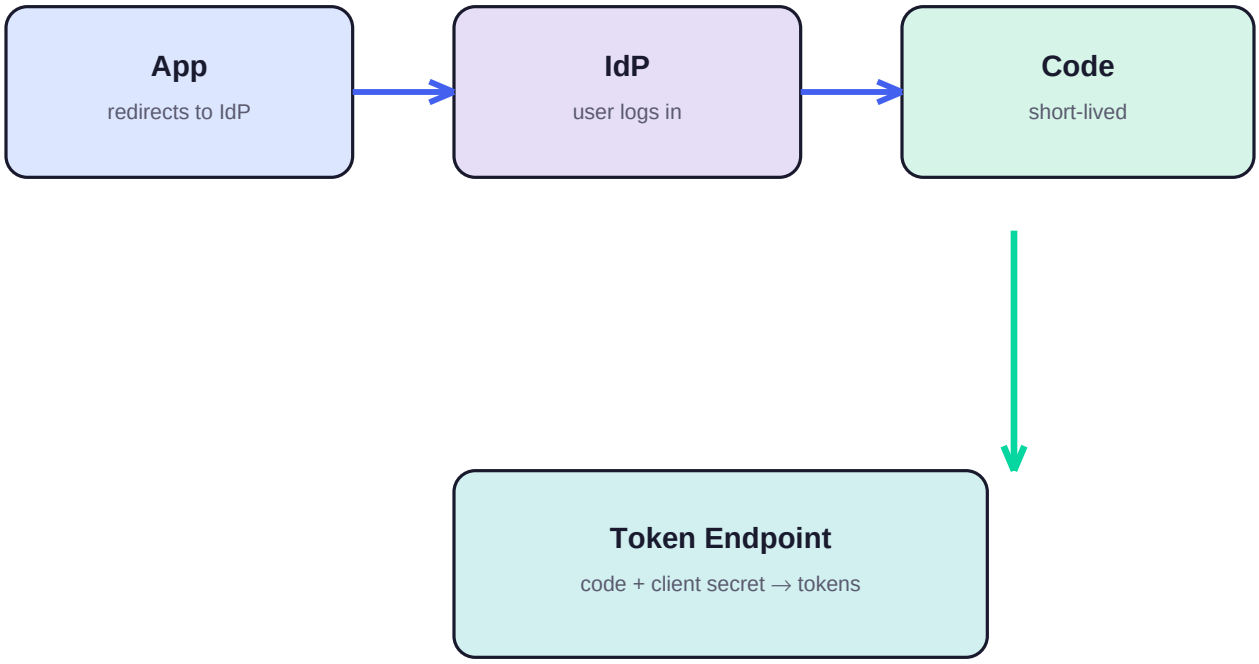


Assertion = XML document: who you are + attributes + signature. Verify signature, check audience + expiry, then create the session.

STEP 3/6

OIDC: Authorization Code + ID Token

Modern federation for web, mobile, APIs (JSON-based).



The code travels via the browser; tokens are exchanged server-to-server. PKCE replaces the client secret for public clients.

STEP 4/6

The ID Token (a JWT)

Who the user is — signed, expiring, verifiable.

Header

alg + kid (which key signed it)

Payload (claims)

sub, iss, aud, exp, iat, nonce, email…

Signature

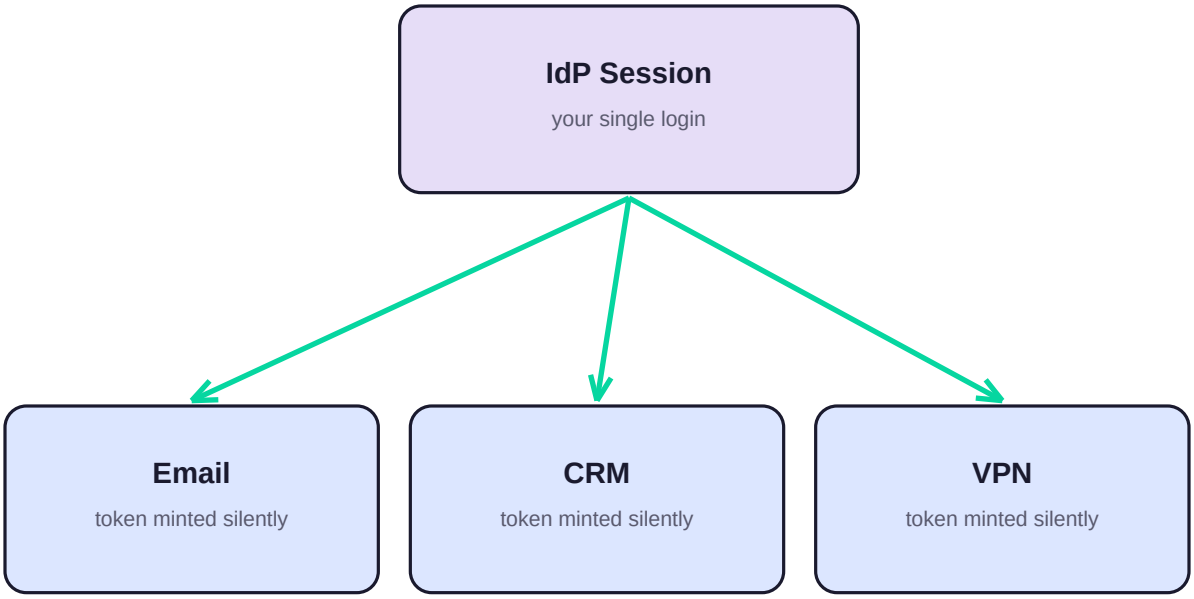
verifiable with the IdP's public key (JWKS)

Always verify: signature, issuer (iss), audience (aud = YOUR app), expiry (exp). A valid-looking token that isn't verified is just a string.

STEP 5/6

The SSO Session

Log in once — roam across every connected app.



Single logout ends the IdP session so tokens stop being minted. Session lifetime and re-auth policies live at the IdP, not in each app.

STEP 6/6

SAML vs OIDC — Picking One

Both do SSO; the ecosystem decides.

SAML

Enterprise legacy: XML assertions, mature IdP support, heavier

OIDC

Modern default: JSON/JWT, built for mobile + APIs, lighter.

- Enterprise app that only speaks SAML → SAML.
- New web/mobile/API → OIDC (authorization code + PKCE).
- Never build your own protocol — delegate auth to the IdP.

STEP ✓I✓

Key Takeaways

OIDC & SAML — Remember

- Federation: the app trusts a signed token from the IdP — passwords stay with the IdP.
- SAML passes signed XML assertions; OIDC passes JWT ID tokens via the code flow.
- Verify every token: signature, issuer, audience, expiry. Unverified = untrusted.
- One IdP session powers SSO across apps; centralize session policy there.
- New builds default to OIDC; keep SAML for legacy enterprise integrations.

Keep exploring

Pair this guide with the matching video walkthroughs
and hands-on labs at interstitiumlabs.dev